

Introduction to security

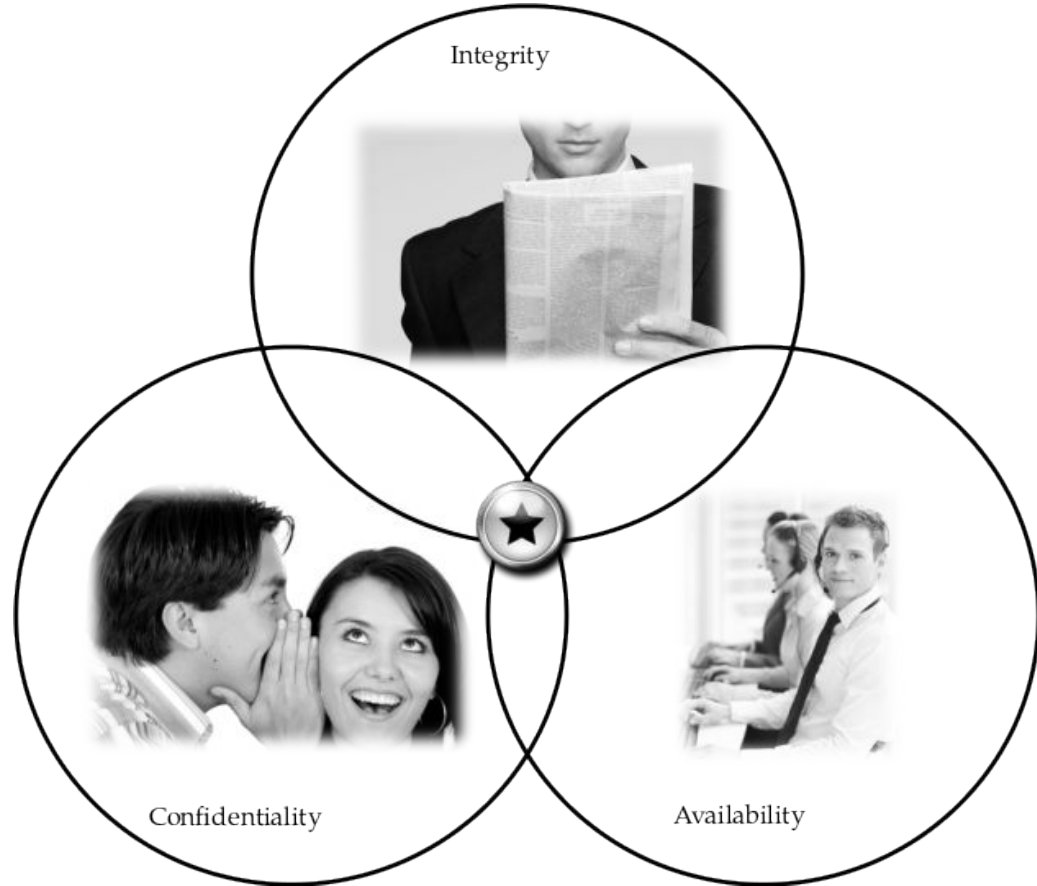
this part of slides are based on
<https://ics.uci.edu/~goodrich/teach/cs201P/notes/Ch01-Introduction.pdf>

[Introduction to Computer Security : Bishop, Matt](#)

- The security of a system, application, or protocol is always relative to
 - A set of desired properties
 - An adversary with specific capabilities
- For example, standard file access permissions in Linux and Windows are not effective against an adversary who can boot from a CD

What to protect?

Basic security components: (CIA)



What to protect?

Basic security components: (CIA)

Confidentiality

the concealment of information or resources

- You cannot enter some offices in university
- You cannot see information of other students in ubys.medeniyet.edu.tr

Access control mechanisms

support confidentiality.

- Example: **a cryptographic key**: scramble data so only people with the key can read/understand

Integrity

the trustworthiness of data or resources

- data integrity
- origin integrity
 - **Authentication**: source of data

Integrity mechanisms

- prevention mechanisms
 - Blocking any unauthorized attempts to change the data
 -
- detection mechanisms.
 - report that the data's integrity is no longer trustworthy

Availability

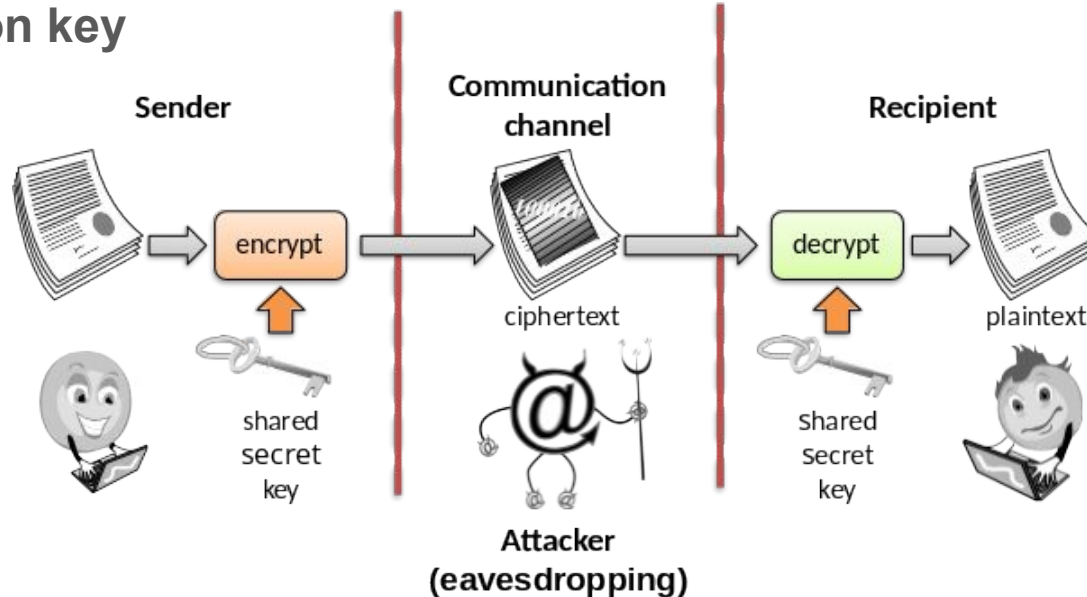
the ability to use the information or resource desire

Attempts to block availability, called **denial of service attacks**

Tools for Confidentiality

Encryption: the transformation of information using a secret,

- the transformed information can only be read using another secret, called the **decryption key**



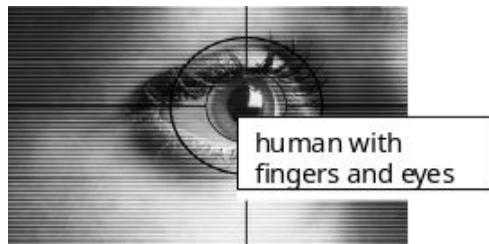
Tools for Confidentiality

- **Access control:** rules and policies that limit access to confidential information to those people and/or systems with a “**need to know.**”

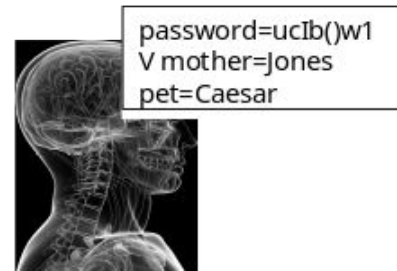
	file 1	file 2	process 1	process 2
process 1	read, write, own	read	read, write, execute, own	write
process 2	append	read, own	read	read, write, execute, own

Tools for Confidentiality

- **Authentication:** the determination of the identity or role that someone has. This determination can be done in a number of different ways
 - something the person has (like a smart card or a radio key fob storing secret keys),
 - something the person knows (like a password),
 - something the person is (like a human with a fingerprint).



Something you are



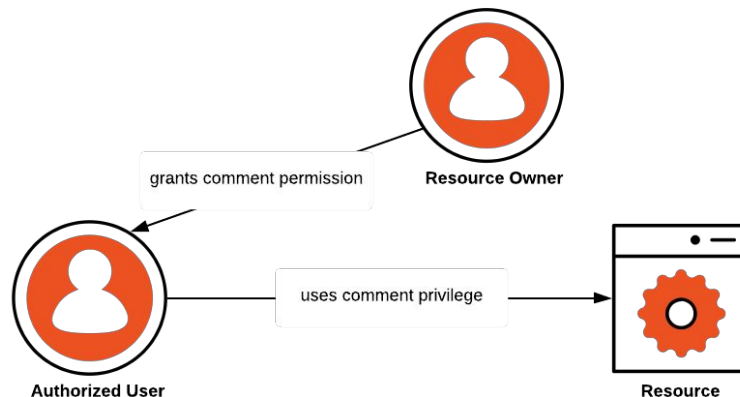
Something you know



Something you have

Tools for Confidentiality

- **Authorization:** the determination if a person or system is allowed access to resources, based on an access control policy.
 - Such authorizations should prevent an attacker from tricking the system into letting him have access to protected resources.
- **Physical security:** the establishment of physical barriers to limit access to protected computational resources.
 - Such barriers include locks on cabinets and doors, the placement of computers in windowless rooms, the use of sound dampening materials, and even the construction of buildings or rooms with walls incorporating copper meshes (called Faraday cages) so that electromagnetic signals cannot enter or exit the enclosure.



<https://auth0.com/intro-to-iam/what-is-authorization>

Tools for Confidentiality

- **Authorization:** the determination if a person or system is allowed access to resources, based on an access control policy.
 - Such authorizations should prevent an attacker from tricking the system into letting him have access to protected resources.
- **Physical security:** the establishment of physical barriers to limit access to protected computational resources.
 - Such barriers include locks on cabinets and doors, the placement of computers in windowless rooms, the use of sound dampening materials, and even the construction of buildings or rooms with walls incorporating copper meshes (called Faraday cages) so that electromagnetic signals cannot enter or exit the enclosure.



e.g.: [OpenID](#) [OAuth 2.0](#)

Integrity and integrity tools

Integrity: the property that information has not be altered in an unauthorized way.

Tools:

Backups: the periodic archiving of data.

Checksums: the computation of a function that maps the contents of a file to a numerical value. A checksum function depends on the entire contents of a file and is designed in a way that even a small change to the input file (such as flipping a single bit) is highly likely to result in a different output value.

Data correcting codes: methods for storing data in such a way that small changes can be easily detected and automatically corrected.

Availability and Tools

Availability: the property that information is accessible and modifiable in a timely fashion by those authorized to do so.

Tools:

Physical protections: infrastructure meant to keep information available even in the event of physical challenges.

Computational redundancies: computers and storage devices that serve as fallbacks in the case of failures.

Other security concepts

Authenticity



Authenticity is the ability to determine that statements, policies, and permissions issued by persons or systems are genuine.

Assurance refers to how trust is provided and managed in computer systems.



Assurance



Anonymity

Anonymity: the property that certain records or transactions not to be attributable to any individual.

Assurance refers to how trust is provided and managed in computer systems.

Trust management depends on:

- **Policies**, which specify behavioral expectations that people or systems have for themselves and others.
 - the designers of an online music system may specify policies that describe how users can access and copy songs.
- **Permissions**, which describe the behaviors that are allowed by the agents that interact with a person or system.
 - permissions for limited access and copying to people who have purchased certain songs.
- **Protections**, which describe mechanisms put in place to enforce permissions and policies.
 - prevent people from unauthorized access and copying of its songs.

Authenticity is the ability to determine that statements, policies, and permissions issued by persons or systems are genuine.

Primary tool:

- **digital signatures.** These are cryptographic computations that allow a person or system to commit to the authenticity of their documents in a unique way that achieves **nonrepudiation**, which is the property that authentic statements issued by some person or system cannot be denied.

Anonymity: the property that certain records or transactions not to be attributable to any individual.

Tools:

- **Aggregation:** the combining of data from many individuals so that disclosed sums or averages cannot be tied to any individual.
- **Mixing:** the intertwining of transactions, information, or communications in a way that cannot be traced to any individual.
- **Proxies:** trusted agents that are willing to engage in actions for an individual in a way that cannot be traced back to that person.
- **Pseudonyms:** fictional identities that can fill in for real identities in communications and transactions, but are otherwise known only to a trusted entity.

Threats to security

A threat is a potential violation of security.

- The violation need not actually occur for there to be a threat

The fact that the violation **might occur** means that

- those actions that could cause it to occur must be guarded against (or prepared for)

Attacks: Those actions

Attackers: Those who execute such actions

Many threats fall into 4 main classes

1. **Disclosure,**
 - unauthorized access to information;
2. **Deception**
 - acceptance of false data
3. **Disruption**
 - interruption or prevention of correct operation
4. **Usurpation**
 - unauthorized control of some part of a system

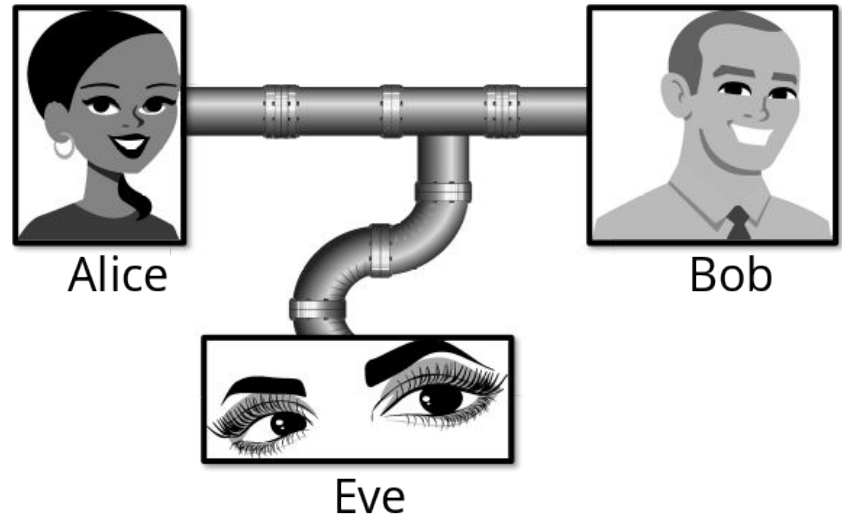
Threats:Snooping (Eavesdropping)

The unauthorized interception of information, is a form of disclosure

It is passive, suggesting simply that some entity is listening to (or reading) communications or browsing through files or system information

Wiretapping, or **passive wiretapping**, is a form of snooping in which a network is monitored

Confidentiality services counter this threat



<https://ics.uci.edu/~goodrich/teach/cs201P/notes/Ch01-Introduction.pdf>

Threats: Modification or alteration

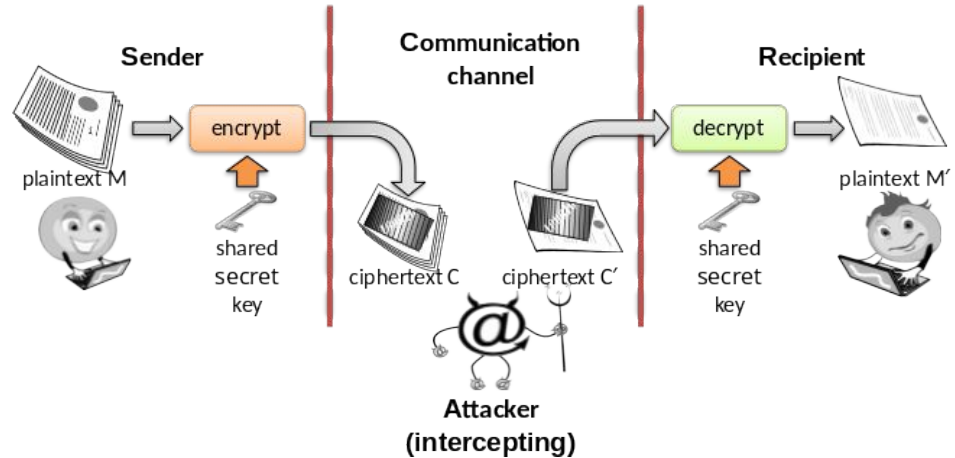
an unauthorized change of information,

- covers three classes of threat

The goal may be deception

Unlike snooping, modification is active

- **man-in-the-middle attack:** an intruder reads messages from the sender and sends (possibly modified) versions to the recipient
 - Integrity services counter this threat



Threats: Masquerading or spoofing

an impersonation of one entity by another,

- is a form of both deception and usurpation.

It lures a victim into believing that the entity with which it is communicating is a different entity

Delegation(an allowed form of masquerading): one entity authorizes a second entity to perform functions on its behalf

if a user tries to log into a computer across the Internet but instead reaches another computer that claims to be the desired one,

- **the user has been spoofed!**



“From: Alice” (really is from Eve)

<https://ics.uci.edu/~goodrich/teach/cs201P/notes/Ch01-Introduction.pdf>

Threats: Repudiation of origin

a false denial that an entity sent (or created) something,

- a form of deception



<https://ics.uci.edu/~goodrich/teach/cs201P/notes/Ch01-Introduction.pdf>

Threats: Denial of receipt

a false denial that an entity received some information or message,

- a form of deception.



<https://ics.uci.edu/~goodrich/teach/cs201P/notes/Ch01-Introduction.pdf>

Threats: Delay

a temporary inhibition of a service

- a form of usurpation
- can play a supporting role in deception.

Let's say: delivery of a message or service requires some time t ;

- **delay**: an attacker can force the delivery to take more than time t ,

If an entity is waiting for an authorization message that is delayed,

- it may query a secondary server for the authorization.
 - The attacker may be unable to masquerade as the primary server,
 - may masquerade as that secondary server and supply incorrect information

Threats: Denial of service

a long-term inhibition of service

- a form of usurpation
- often used with other mechanisms to deceive

denial may occur

- at the source
 - preventing the server from obtaining the resources needed to perform its function
- at the destination
 - blocking the communications from the server
- or along the intermediate path
 - discarding messages from either the client or the server, or both

email spam to fill-up a mail queue



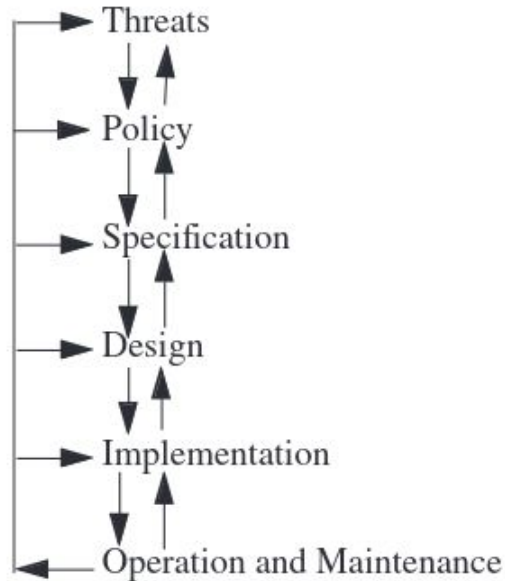
Alice

Availability mechanisms counter this threat.

Denial of service or delay may result from **direct attacks** or from **non-security related** problems

- we view it as an attempt to breach system security
 - it compromises system security,
 - or is part of a sequence of events leading to the compromise of a system,

Security life cycle

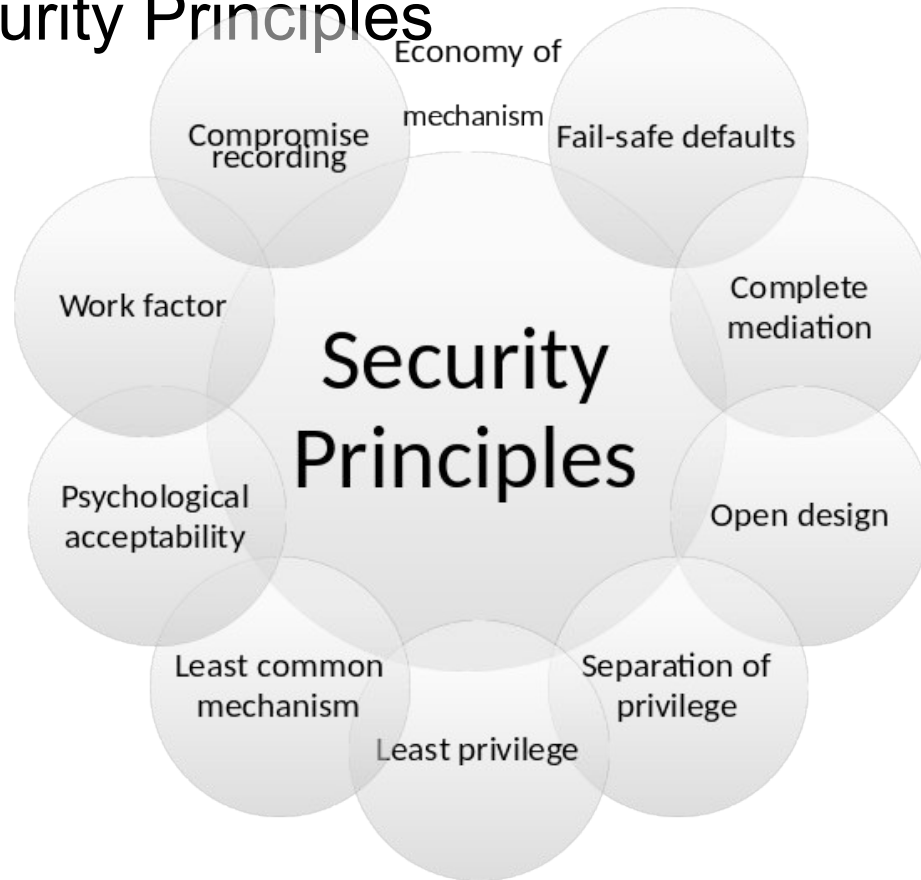


Human issues pervade each stage of the cycle and each cycle feeds info back

Example: A major corporation decided to improve its security.

- It hired consultants,
- determined the threats,
- and created a policy.
- From the policy, the consultants derived several specifications that the security mechanisms had to meet.
- They then developed a design that would meet the specifications
- During the implementation phase,
 - the company discovered that employees could connect modems to the telephones without being detected.
 - The design required all incoming connections to go through a firewall
 - **The design had to be modified to** divide systems into two classes:
 - systems connected to “the outside,” which were put outside the firewall;
 - and all other systems, which were put behind the firewall.
 -
- **The operation and maintenance stage is critical to the life cycle**
 - The company discovers that several “trusted” hosts (those allowed to log in without authentication) were physically outside the control of the company.
 - **This violates policy!**

The Ten Security Principles



Access Control

Users and groups

Authentication

Passwords

File protection

Access control lists

Which users can read/write which files?

Are my files really safe?

What does it mean to be root?

What do we really want to control?

Access Control Matrices

columns are
objects

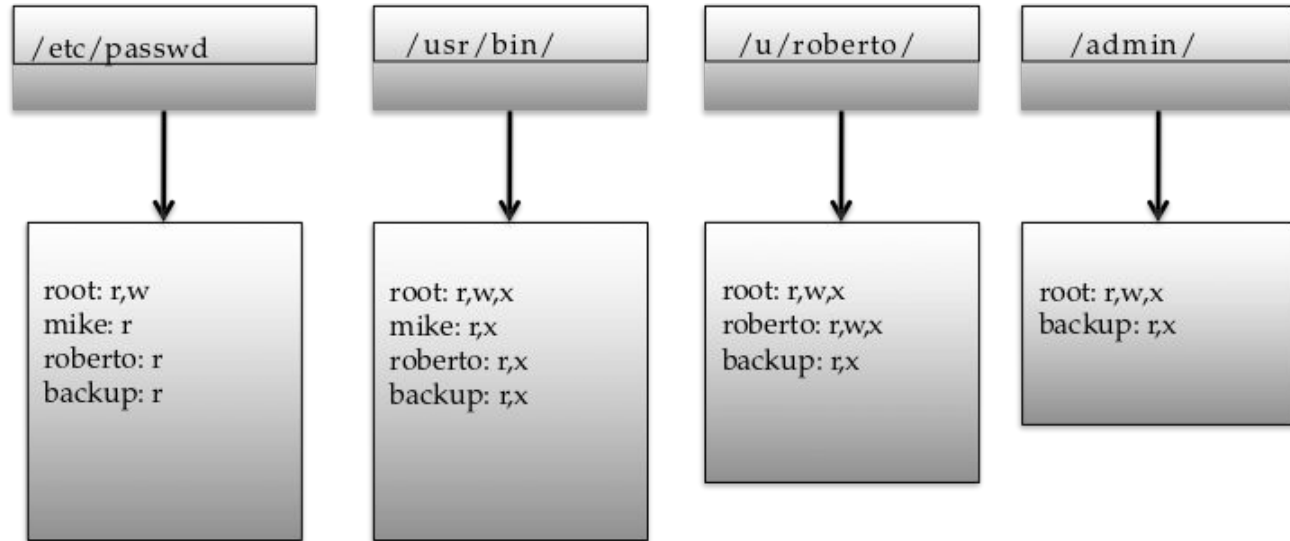
rows are
subjects

	/etc/passwd	/usr/bin/	/u/roberto/	/admin/
root	read, write	read, write, exec	read, write, exec	read, write, exec
mike	read	read, exec		
roberto	read	read, exec	read, write, exec	
backup	read	read, exec	read, exec	read, exec
...	...	...	...	...

permissions

Access Control Lists

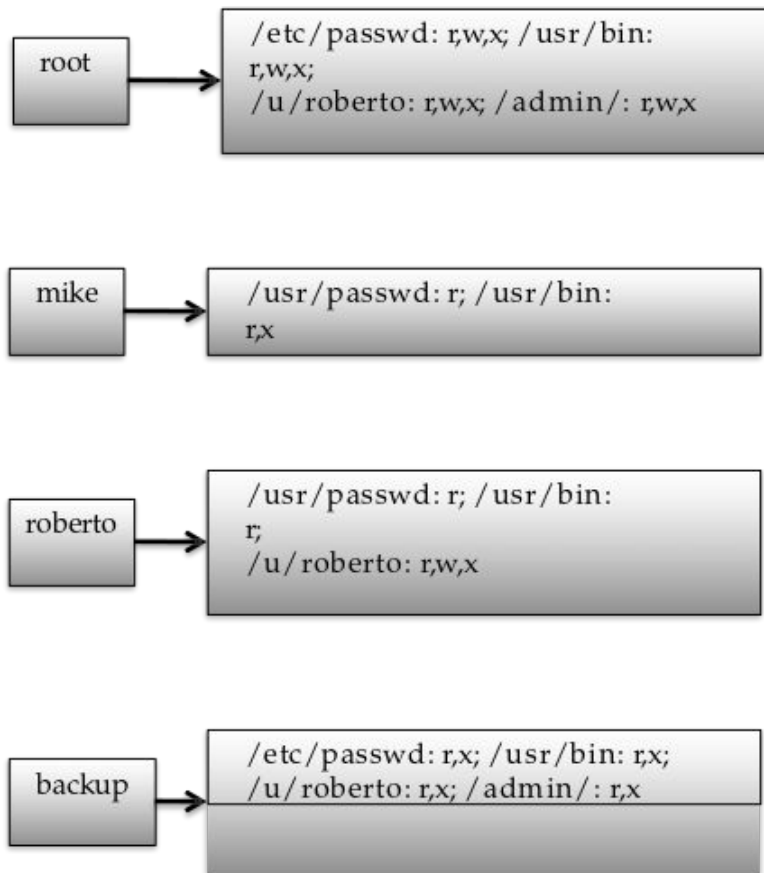
It defines, for each object, *o*, a list, *L*, called *o*'s access control list, which enumerates all the subjects that have access rights for *o* and, for each such subject, *s*, gives the access rights that *s* has for object *o*.



Capabilities

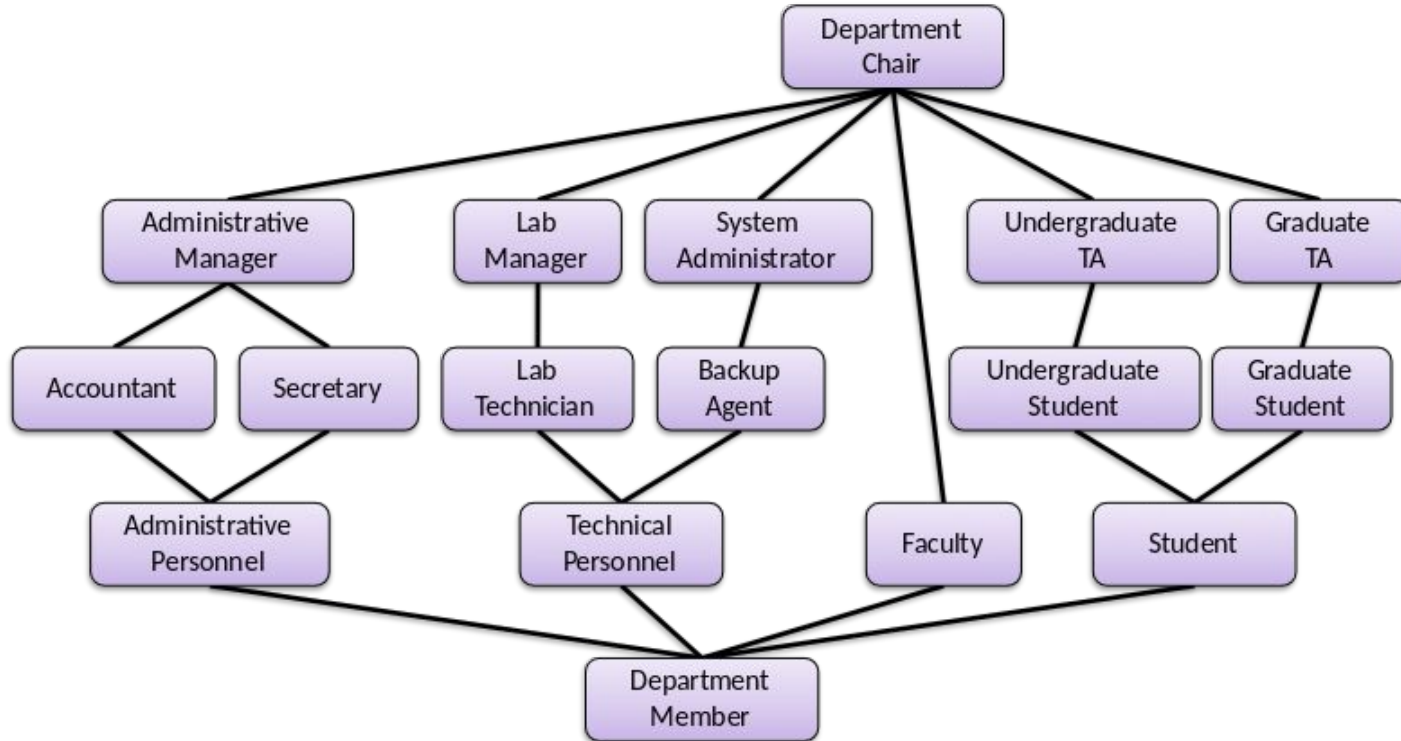
Takes a subject- centered approach to access control.

It defines, for each subject *s*, the list of the objects for which *s* has nonempty access control rights, together with the specific rights for each such object.



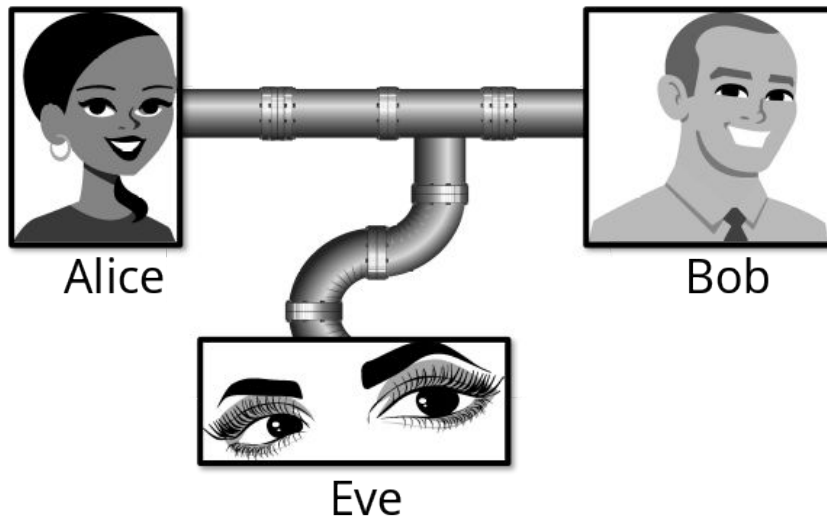
Role-based Access Control

Define roles and then specify access control rights for these roles, rather than for subjects directly



Cryptographic concepts

Encryption: a means to allow two parties, customarily called Alice and Bob, to establish confidential communication over an insecure channel that is subject to eavesdropping.



Encryption and Decryption

The message **M** is called the **plaintext**.

Alice will convert **plaintext M** to an encrypted form

- Alice uses an **encryption algorithm E** that outputs a **ciphertext C** for M.

As equations:

$$\mathbf{C} = \mathbf{E}(\mathbf{M})$$

$$\mathbf{M} = \mathbf{D}(\mathbf{C})$$

The encryption and decryption algorithms are chosen so that it is infeasible for someone other than Alice and Bob to determine plaintext M from ciphertext C.

ciphertext C can be transmitted over an insecure channel that can be eavesdropped by an adversary.

Classical cryptosystems (single-key or symmetric cryptosystems)

Substitution Ciphers

A substitution cipher changes characters in the plaintext to produce the ciphertext.

	A	B	C	D	E	F	G	H	I	J	K	L	M
A	A	B	C	D	E	F	G	H	I	J	K	L	M
B	B	C	D	E	F	G	H	I	J	K	L	M	N
C	C	D	E	F	G	H	I	J	K	L	M	N	O
D	D	E	F	G	H	I	J	K	L	M	N	O	P
E	E	F	G	H	I	J	K	L	M	N	O	P	Q
F	F	G	H	I	J	K	L	M	N	O	P	Q	R
G	G	H	I	J	K	L	M	N	O	P	Q	R	S

- Transposition ciphers
- Cesar cipher
- Vigenère cipher
 - A longer key, uses tableau

EXAMPLE: The first line of a limerick is enciphered using the key “BENCH,” as follows.

Key	B	E	N	C	H	B	E	N	C	H	B	E	N	C	H	B	E	N	C	H
Plaintext	A	L	I	M	E	R	I	C	K	P	A	C	K	S	L	A	U	G	H	S
Ciphertext	B	P	V	O	L	S	M	P	M	W	B	G	X	U	S	B	Y	T	J	Z

One-Time Pad: if the key as long as the text

Public Key Cryptography

Two keys: encipherment and decipherment keys

Public (encipherment) **key** is public!

Private (decipherment) **key** is known only to owner!

RSA

$$c = m^e \bmod n$$

$$m = c^d \bmod n$$

- $\phi(n)$
 - the number of numbers less than n with no factors in common with n
- Choose e : $e < n$ relatively prime to $\phi(n)$.
- Find d : $ed \bmod \phi(n) = 1$

The public key is (e, n)

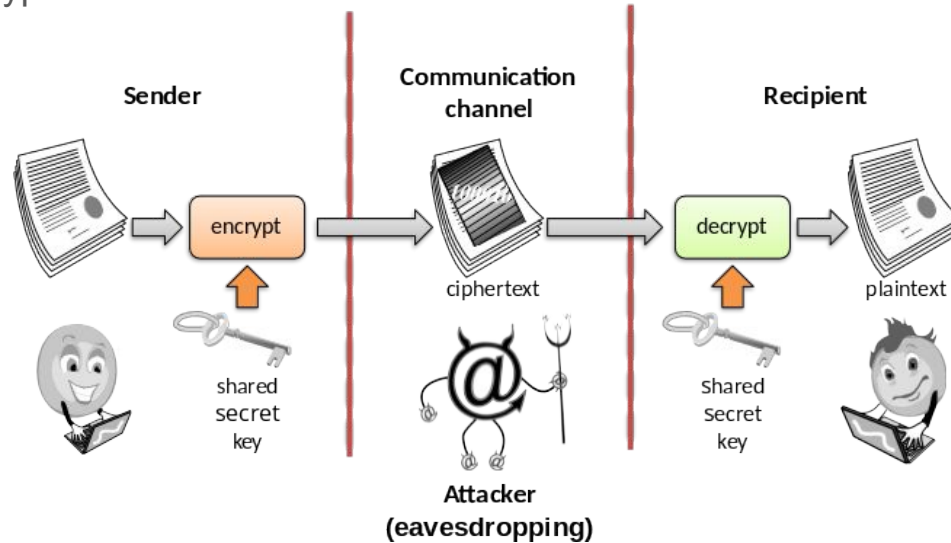
the private key is d

$n = pq$, p and q primes

In addition to confidentiality, RSA can provide data and origin authentication.

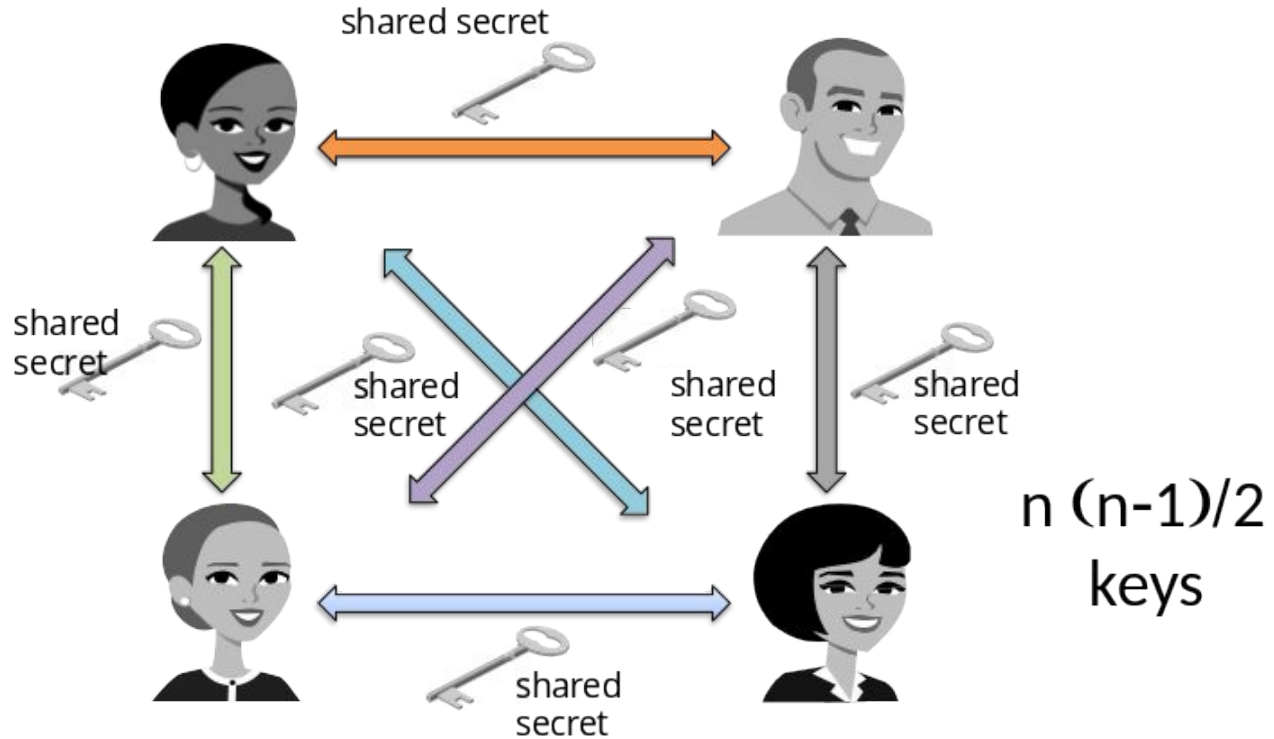
Symmetric cryptosystems

Alice and Bob share a secret key, which is used for both encryption and decryption.



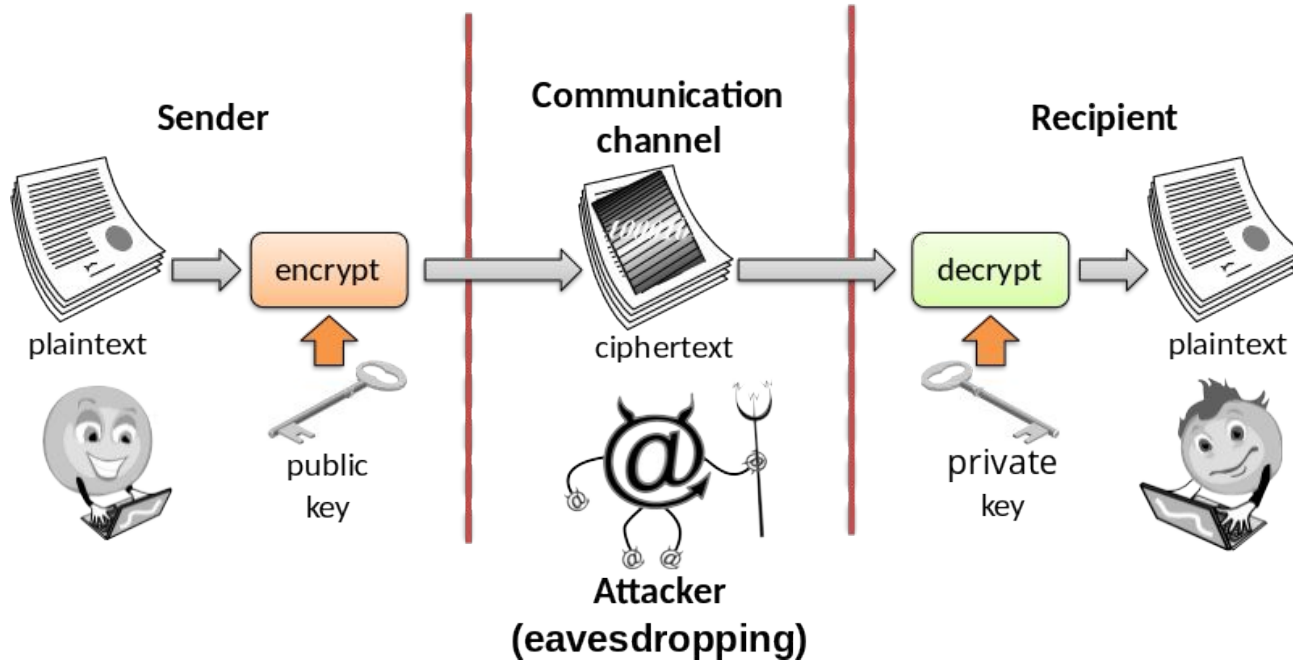
Symmetric key Distribution

Requires each pair of communicating parties to share a (separate) secret key.



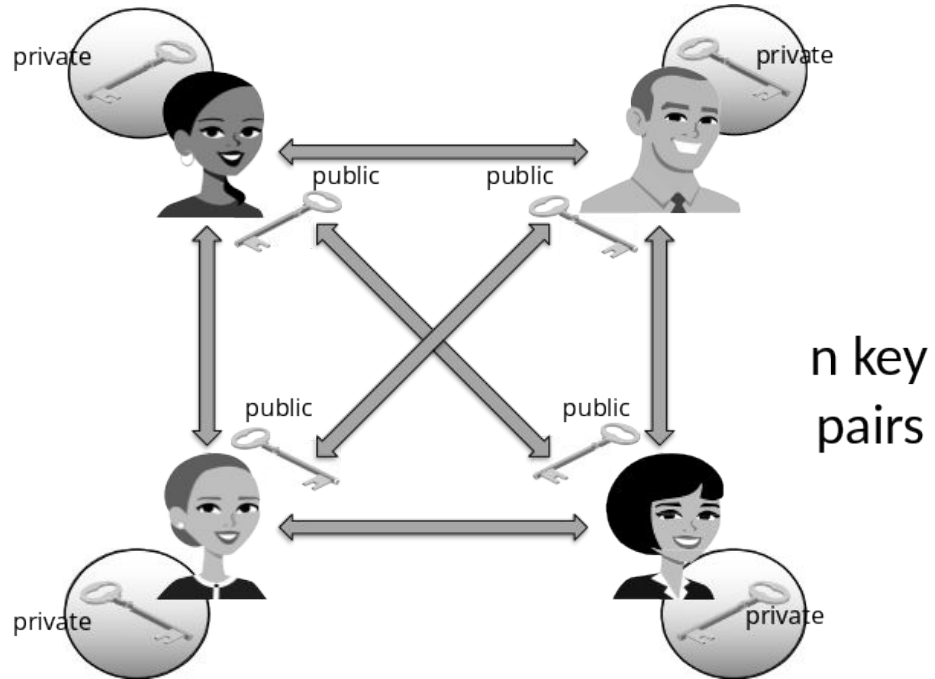
Public-Key Cryptography

Separate keys are used for encryption and decryption.



Public Distribution

Only one key is needed for each recipient



Digital Signatures

Public-key encryption provides a method for doing digital signatures

To sign a message, M ,

- Alice just encrypts it with her private key, SA , creating $C = E_{SA}(M)$.

Anyone can decrypt this message using Alice's public key,

- $M' = D_{PA}(C)$, and compare that to the message M .

Cryptographic Hash Functions

A checksum on a message, M , that is:

One-way:

- it should be easy to compute $Y=H(M)$,
- but hard to find M given only Y

Collision-resistant:

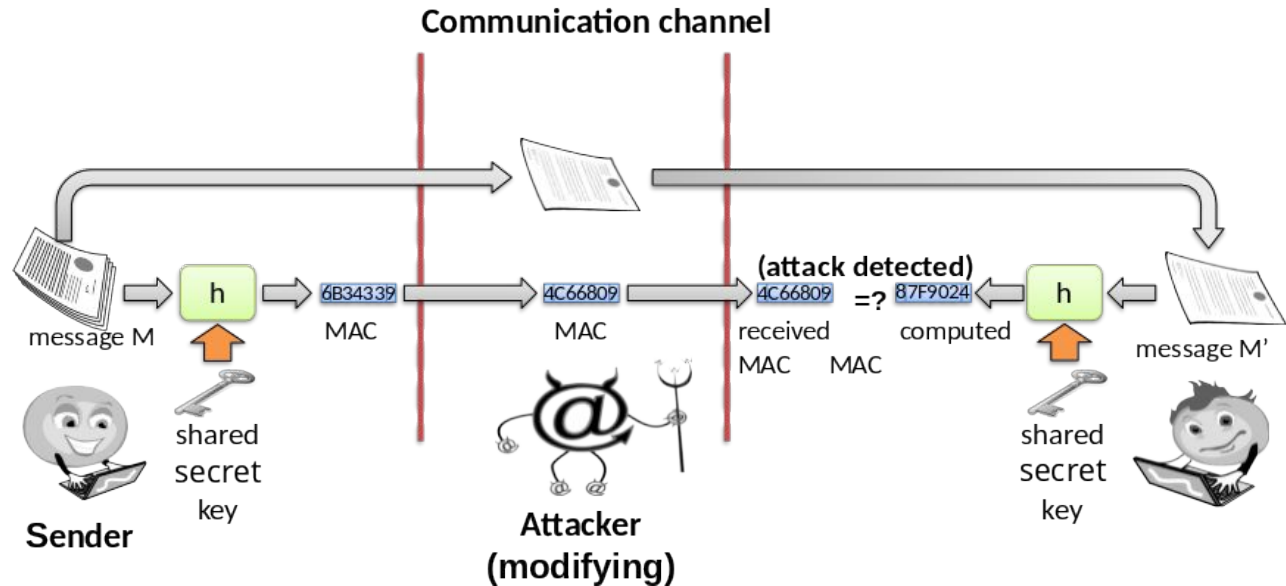
- it should be hard to find two messages, M and N , such that $H(M)=H(N)$.

Examples: SHA-1, SHA-256.

Message Authentication Codes

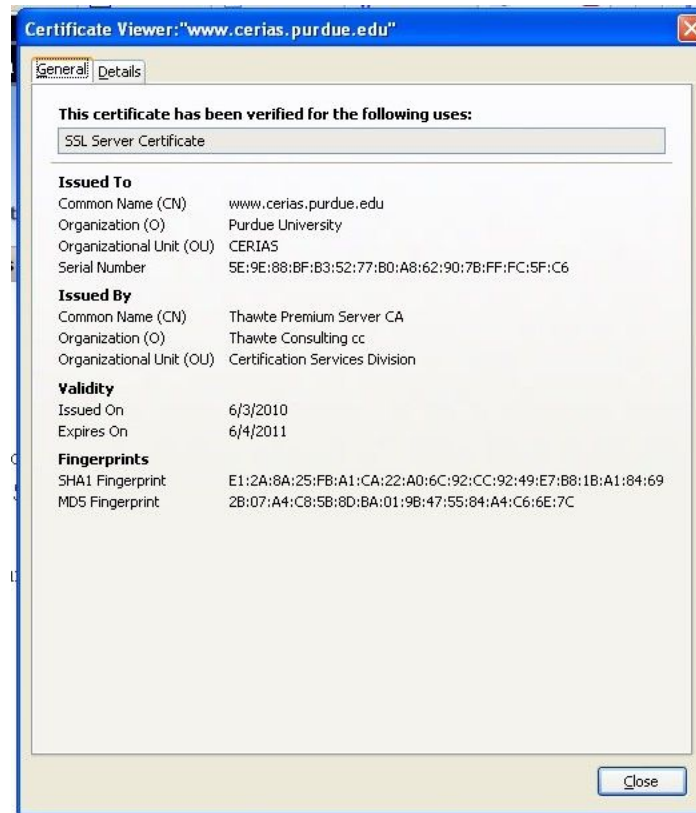
Allows for Alice and Bob to have data integrity, if they share a secret key.

Given a message M,
Alice computes $H(K||M)$
and sends M and this hash to Bob.



Digital Certificates

certificate authority (CA) digitally signs a binding between an identity and the public key for that identity.



Passwords

A short sequence of characters used as a means to authenticate someone via a secret that they know.

Userid:

Password:

What is a strong password

- UPPER/lower case characters
- Special characters
- Numbers

When is a password strong?

Seattle1

M1ke03

P@\$w0rd

TD2k5secV

Password complexity

Odd characters make pass strong

A fixed 6 symbols password:

- Numbers
 - $10^6 = 1,000,000$
- UPPER or lower case characters
 - $26^6 = 308,915,776$
- UPPER and lower case characters
 - $52^6 = 19,770,609,664$
- 32 special characters
 - (&, %, \$, £, “, |, ^, §, etc.)
 - $32^6 = 1,073,741,824$

94 practical symbols available

- $94^6 = 689,869,781,056$

ASCII standard 7 bit $2^7 = 128$ symbols

- $128^6 = 4,398,046,511,104$

Password length

5 characters: $94^5 =$	7,339,040,224
6 characters: $94^6 =$	689,869,781,056
7 characters: $94^7 =$	64,847,759,419,264
8 characters: $94^8 =$	6,095,689,385,410,816
9 characters: $94^9 =$	572,994,802,228,616,704

Password Validity: Brute Force Test

Password does not change for 60 days

how many passwords should I try for each second?

5 characters:	1,415 PW /sec
6 characters:	133,076 PW /sec
7 characters:	12,509,214 PW /sec
8 characters:	1,175,866,008 PW /sec
9 characters:	110,531,404,750 PW /sec

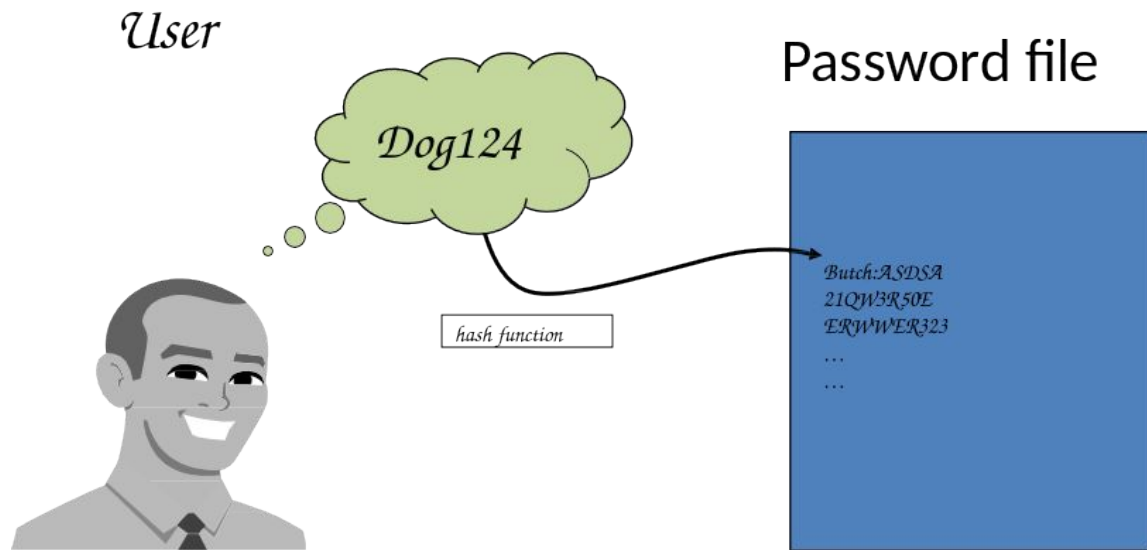
Secure Passwords

A strong password includes characters from at least three of the following groups:

Group	Example
Lowercase letters	a, b, c, ...
Uppercase letters	A, B, C, ...
Numerals	0, 1, 2, 3, 4, 5, 6, 7, 8, 9
Non-alphanumeric (symbols)	() ` ~ ! @ # \$ % ^ & * - + = \ { } [] : ; " ' < > , . ? /
Unicode characters	€, Γ, f, and λ

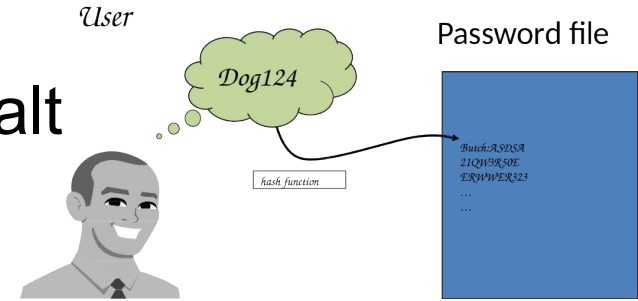
eg. "I re@lly want to buy 11 Dogs!"

How a password is stored?



- ★ Add “salt” to avoid the same password being encrypted to the same value
 - $H(\text{dog124} + \text{salt})$
 - Save $\text{salt} + h(\text{dog124} + \text{salt})$

How a password is stored: random salt



Username	String to be hashed	Hashed value = SHA256
user1	password123	EF92B778BAFE771E89245B89ECBC08A44A4E166C06659911881F383D4473E94F
user2	password123	EF92B778BAFE771E89245B89ECBC08A44A4E166C06659911881F383D4473E94F

Username	Salt value	String to be hashed	Hashed value = SHA256 (Password + Salt value)
user1	D;%yL9TS:5Pa lS/d	password123D;%yL9TS:5P alS/d	9C9B913EB1B6254F4737CE947EFD16F16E916F9D6EE5C1102A2002E4 8D4C88BD
user2	)<,-<U(jLezy 4j>*	password123)<,-<U(jLez y4j>*	6058B4EB46BD6487298B59440EC8E70EAE482239FF2B4E7CA69950DF BD5532F2